

2026 年春季学期《网络空间安全综合实验》课程要求

崔宝江

cuibj@bupt.edu.cn

13611330827

网络安全综合实验是综合性的创新性的综合设计类实验，主要目的是使学生将三年所学内容融会贯通，学会网络安全类知识的综合运用。并且，希望学生在自己有兴趣和擅长的网络安全领域，能够自己设计并完成相应实验。

一. 实验任务要求

本次综合性实验，6-10 人为一组分组协同完成（最多人数不能超过 10 人，可少于 6 人），每组任务可从如下 4 个实验中任选其一，完成实验任务要求。

（一）基于大模型智能体的开源项目安全缺陷自动审计和验证系统

1、实验背景

随着大语言模型（LLM）技术的快速发展，基于 LLM 的智能体（Agent）已经能够在代码安全审计领域发挥越来越重要的作用。当前，由自主 LLM 智能体完成的审计已在关键基础软件中发现大量高危漏洞。业界已涌现出 DeepAudit、AgentStalker、OpenSecurity、deepfake 等多个开源或商业化的智能体安全审计系统。然而，直接使用大模型进行代码审计仍面临误报率高、缺乏证据链、结果不可复现等核心挑战。如何构建一个可审计、可验证、可复现的自动化安全缺陷审计系统，是该领域的核心研究问题。

要求学生综合运用智能体设计、代码分析与漏洞验证等技术，构建一个能够对开源项目进行自动安全审计和漏洞验证的端到端系统。

2、实验目标

- （1）理解并实践大模型智能体的设计与开发流程
- （2）构建一个多智能体协作的安全审计系统，实现从代码扫描到漏洞验证的完整链路
- （3）培养系统性解决复杂工程问题的能力

3、系统功能要求（参考性要求，不限制新的思路和新的功能）

(1) 代码仓库解析模块

- a) 支持输入 GitHub/GitLab 仓库 URL 或本地代码目录;
- b) 自动识别项目编程语言;
- c) 提取项目文件结构、依赖关系等元信息;

(2) 智能体审计模块 (核心)

基于大模型, 构建至少多个协作智能体:

- a) 扫描智能体, 负责对代码进行静态分析, 识别潜在的 SQL 注入、命令注入、路径遍历、硬编码密钥等安全风险
- b) 验证智能体, 对扫描结果进行独立复核, 过滤误报

智能体需具备工具调用能力 (如调用 SAST 工具、执行代码分析脚本等), 例如 MCP+Skills

(3) 漏洞自动利用模块

对于验证存在的安全漏洞, 实现自动化的漏洞利用, 形成漏洞利用代码。

输出每个漏洞的证据链 (包含文件位置、调用路径、验证结果等)

(4) 报告生成模块

自动生成结构化的审计报告。

报告需包含: 漏洞列表、严重等级、证据链、修复建议

4、开源参考项目的对比

通过对比其他开源项目, 验证在某些方面自研系统的创新性。

- 1) **DeepAudit**: 国内首个开源的代码漏洞挖掘多智能体系统, 支持自主协作审计 + 自动化沙箱 PoC 验证
- 2) **AgentStalker**: 首个将 LLM 智能体作为系统进行端到端安全审计的框架, 包含静态建模→攻击图合成→沙箱动态验证→证据裁决的完整流程
- 3) **OpenSecurity**: AI 驱动的多领域安全分析 Agent 平台, LLM 可自主编排工具链完成端到端安全分析
- 4) **ESAA-Security**: 事件溯源架构的安全审计系统, 将安全审计视为确定性流水线而非自由格式清单
- 5) **Sandyaa**: 自主代码审计工具, 可递归深入挖掘直到发现并证明真实漏洞

5、待测目标要求

不低于 20 款主流开源项目检测，包括但不限于 openvpn、maccms v10 等。

（二）面向大模型智能体和关键模块的恶意行为检测系统

1、实验背景

2026 年 7 月，一则安全事件震动了全球 AI 产业：开发者逆向分析发现，Anthropic 公司的 AI 编程智能体 Claude Code 从 2.1.91 版本（2026 年 4 月发布）起内置了一套隐蔽的用户检测与身份标记机制。该机制会读取用户系统时区（如 Asia/Shanghai）、检查代理地址中是否包含中国厂商关键词（如阿里、字节、百度等），并通过 Unicode 隐写术将检测结果编码到系统提示词中——将正常撇号（U+0027）替换为右单引号（U+2019）、修饰符撇号（U+02BC）等肉眼不可见的字符，随每次 API 请求发往 Anthropic 服务器。核心逻辑做了加密混淆，版本更新日志却只字未提。Anthropic 团队事后承认这是“防止未授权转售和模型蒸馏”的实验性措施，但该事件已导致阿里巴巴全面禁止内部员工使用 Anthropic 全系产品。

这并非孤例。研究表明，42,447 个 Agent Skills 中有 26.1% 存在漏洞，5.2% 可能为恶意。ClawHub、Cisco、Vercel 三大平台的 Skills 安全扫描器全部可在 1 小时内被绕过。智能体后门攻击（如沉睡智能体式后门）可在标准安全测试期间休眠，当输入中出现特定触发器时执行恶意行为。AI 智能体供应链中的后门威胁已成为真实存在的系统性风险。

在此背景下，如何系统性地检测大模型智能体及其关键模块（模型权重、Skill 文件、工具调用链、MCP 服务器等）中潜藏的恶意行为和后门，已成为 AI 安全领域的紧迫课题。本作业要求学生构建一个多维度恶意行为检测系统，能够对智能体及其生态组件进行自动化安全分析。

2、实验目标

- （1）深入理解大模型智能体生态的安全威胁模型，特别是后门注入、供应链攻击、隐蔽遥测等攻击向量
- （2）掌握智能体恶意行为的静态分析（代码审计、模式匹配、依赖分析）与动态分析（沙箱执行、行为监控、污点追踪）技术
- （3）构建一个覆盖模型权重、Skill 文件、工具调用链等多层次的智能体安全检

测系统

(4) 培养从真实安全事件中抽象问题、设计解决方案的系统性安全研究能力

3、系统功能要求（参考性要求，不限制新的思路和新的功能）

系统需实现以下核心功能模块：

(1) 智能体组件识别与解析模块

支持输入一个智能体项目（如 Claude Code 插件/Skill、MCP 服务器、开源 Agent 框架等），自动识别并提取智能体的关键组件：

- a) Skill 文件（SKILL.md 及其引用文件）
- b) 模型权重/适配器（如 LoRA 权重文件）
- c) 工具定义与调用链
- d) 依赖组件清单（构建 AI-SBOM，即人工智能软件物料清单）
- e) 配置文件与环境变量

(2) 静态检测模块（核心）

基于多种检测方法对智能体组件进行静态分析：

- a) 模式匹配检测：基于 YARA 规则或正则表达式，检测 Base64 编码载荷、`exec()`/`eval()`等危险函数、混淆代码、二进制 blob 等可疑模式
- b) 语义/意图分析：利用开源大模型对 Skill 声明功能与实际行为进行语义一致性检测，识别“功能声明与实际行为严重偏离”的恶意 Skill
- c) 供应链依赖分析：扫描依赖组件中的已知漏洞（CVE），检测可疑的依赖版本或来源
- d) （可选进阶）隐写术检测：针对 Claude Code 事件中暴露的 Unicode 隐写术，开发专门的字符隐写检测模块

(3) 动态验证模块

- a) 监控运行时行为，至少覆盖以下维度：
 - 文件系统访问（读取/写入/删除）
 - 网络连接（C2 回连、数据外传）
 - 进程创建与 Shell 命令执行
 - 敏感数据流（API 密钥、凭证等）
- b) 实现污点追踪：追踪敏感数据从输入源到敏感操作（sink）的流动路径

c) 输出行为证据链，标记可疑行为。

(4) 检测报告与风险评估模块

生成结构化检测报告，包含：

- a) 每个检测项的风险等级（高危/中危/低危/安全）
- b) 证据详情（文件位置、代码片段、行为日志）
- c) 综合风险评分
- d) 修复/缓解建议

4、开源参考项目的对比

通过对比其他开源项目，验证在某些方面自研系统的创新性。

5、待测目标要求

包括但不限于 10 款主流大模型的相关智能体或模块。

(三) 开源情报资源中潜在行为和关系的大模型深度分析系统

1、实验背景

开源情报（Open Source Intelligence, OSINT）是指从公开可获取的信息源中收集、分析和利用情报的过程，在国家安全、军事态势感知、网络安全威胁监测、有组织犯罪打击等领域发挥着日益关键的作用。传统 OSINT 分析方法主要依赖人工研判，受限于思维定式、主观臆断和效率低下等问题，预警失败案例频发。随着大语言模型（LLM）技术的突破，其强大的语义理解、信息抽取、多步推理和知识融合能力，为开源情报分析开辟了全新的技术路径。

当前，全球安全态势日趋复杂：APT 组织（如 Kimsuky、Lazarus、APT28 等）不断演进攻击手法，2025 年已出现首个 AI 驱动的恶意软件 LameHug，据推测与俄罗斯 APT28 组织存在关联；国家级 APT 组织（如中国、朝鲜、伊朗关联的黑客组织）已被证实利用 Gemini 等 AI 工具进行目标侦察、漏洞研究和攻击规划；有组织犯罪集团在东南亚等地规模化运营网络诈骗产业链，利用 AI、深度伪造和加密货币等技术，年损失规模超过数百亿美元；与此同时，军事领域的大语言模型应用也在快速推进，美军已开展生成式 AI 在情报收集与分析中的实战测试。

在此背景下，如何系统性地利用大模型技术，从海量开源情报中自动识别 APT 组织和犯罪团伙，并深度挖掘其间的潜在行为模式与关联关系，已成为情报

分析、网络安全和公共安全领域的核心研究课题。本作业要求学生构建一个基于大模型的端到端开源情报深度分析系统，能够对多源异构情报数据进行自动化采集、实体识别、关系抽取、行为建模与知识推理。

2、实验目标

（1）深入理解开源情报（OSINT）的核心概念、方法论及其在 APT 监测、犯罪打击中的应用场景

（2）掌握基于大语言模型的命名实体识别（NER）、关系抽取（RE）、事件抽取和知识图谱构建等核心技术

（3）构建一个覆盖“数据采集→实体识别→关系抽取→行为分析→知识图谱构建→智能报告生成”完整链路的开源情报分析系统

（4）培养从真实安全事件和情报数据中发现问题、设计解决方案的系统性分析能力

3、系统功能要求（参考性要求，不限制新的思路和新的功能）

系统需实现以下核心功能模块：

（1）多源情报数据采集与预处理模块

支持从至少三种不同类型的开源情报源自动采集数据：

- a) 网络安全类：如威胁情报报告、CVE 漏洞库、安全博客、CERT 公告等
- b) 新闻媒体类：如国际新闻报道、政府公报、军事动态等
- c) 社交媒体/论坛类：如 Twitter/X、Telegram 安全频道、黑客论坛等

实现数据的自动清洗、去重、结构化与标准化

支持中英文双语情报数据的处理

（2）实体识别与关系抽取模块（核心）

基于大模型实现以下功能：

命名实体识别（NER）：自动识别情报文本中的关键实体，至少包括：

组织实体：APT 组织名称（如 APT28、Lazarus、Kimsuky、APT43 等）、犯罪团伙、军事单位、政府机构等

人员实体：关键人物、黑客、军事指挥官等

技术实体：恶意软件名称、漏洞编号（CVE）、攻击工具、TTP（战术、技术和程序）等

地理实体：国家、地区、军事基地、冲突区域等

时间实体：攻击时间线、事件发生时间等

关系抽取（RE）：自动识别实体之间的语义关系，至少包括：

组织归属关系（如“APT28 关联 LameHug 恶意软件”）

攻击行为关系（如“Lazarus 组织实施加密货币盗窃”）

时间序列关系（如“事件 A 发生于事件 B 之前”）

因果关联关系（如“漏洞 X 导致攻击 Y”）

（3）基于大模型的行为模式分析与威胁建模模块

- a) 基于大模型实现 APT 组织行为分析：基于抽取的实体和关系，识别 APT 组织的攻击生命周期（如侦察→武器化→投递→利用→安装→C2→目标达成），映射到 MITRE ATT&CK 框架
- b) 基于大模型实现犯罪团伙网络分析：识别犯罪团伙的组织结构、成员关联、资金流向、作案手法等，构建犯罪生态网络
- c) 或者其他感兴趣的分析场景

实现基于大模型的智能推理：能够根据已知情报推断未知关联和潜在威胁

（4）知识图谱构建与可视化模块

将抽取的实体、关系和行为模式构建为知识图谱（推荐 Neo4j 或 GraphRAG）

知识图谱需支持：

- a) 多维度查询（按组织、时间、地区、攻击类型等）
- b) 关联路径追踪（如“某 APT 组织→使用的恶意软件→攻击的目标→时间线”）
- c) 动态更新（新情报自动融入图谱）
- d) 提供知识图谱的可视化展示界面

（5）智能报告生成模块

自动生成结构化的情报分析报告，至少包含：

- a) 目标组织/团体的完整画像（名称、别名、活跃时间、地理范围、主要活动等）
- b) 行为模式总结（攻击手法、目标偏好、技术演进等）
- c) 关联关系网络（与其他组织/人员/事件的关联）

d) 时间线梳理（关键事件的时间序列）

e) 威胁等级评估与预警建议

4、开源参考项目的对比

通过对比其他开源项目，验证在某些方面自研系统的创新性。

5、待测目标要求

包括但不限于 3 个目标组织/团体。

（四）基于大模型的攻击行为全方位检测、捕获和溯源

1、实验背景

网络攻击的形态正在发生深刻变革。攻击者正在从键盘前消失——云鼎实验室观测到一批真实攻击案例，涉及 Claude Code Agent、CyberStrike-AI、OpenClaw、OpenCode 等不同工具和框架，这些攻击案例有着共同的执行形态：攻击链里开始出现 LLM 生成的解释、代码、试错和路径切换。APT 组织的攻击链通常涉及侦察、渗透、横向移动和数据外泄等多个阶段，采用隐蔽的命令与控制通信机制，长期潜伏以窃取数据或实施破坏。

与此同时，AI 供应链攻击的目标选择已发生根本性位移——攻击者不再满足于随机漏洞扫描，而是主动锁定 AI 技术栈中的关键枢纽节点实施定向打击。MITRE 知识库已将对手利用 AI 和 LLM 的行为从推测转为有记录、有归因的实际活动。

面对这一形势，传统的“检测-响应”模式已力不从心。尽管端点检测与响应（EDR）、入侵检测系统（IDS）等安全防线已广泛部署，APT 攻击仍持续突破防护并造成严重后果。大语言模型（LLM）强大的语义理解、多步推理和知识融合能力，为网络攻击的检测（Detection）、捕获（Capture）和溯源（Attribution）提供了全新的技术路径。

检测层面，LLM-APTDS 等系统已利用多模型协同检测架构，通过 LLM 的语义理解实现对日志异常的精准定位；PROVSEEK 通过 LLM 驱动的智能体框架，在威胁检测任务上实现了 22%/29%的精确率/召回率提升。

捕获层面，智能体安全审计框架（如 AgentStalker）实现了端到端的攻击行为捕获——从静态建模到攻击图合成，再到沙箱动态验证与证据裁决的完整链路。

溯源层面，TAA-EPLMR 提出了证据路径增强的 LLM 推理方法，将威胁情报知识图谱与 LLM 深度融合，实现攻击者归因推理；HunterAgent 在反取证场景下实现了 86.1% 的平均 F1 值，将路径级幻觉从 61.5% 降至 6.4%。

在此背景下，如何系统性构建一个基于大模型的攻击行为全方位检测、捕获与溯源系统，已成为网络安全领域最前沿的研究课题之一。

2、实验目标

(1) 深入理解网络攻击（特别是 APT 攻击）的生命周期模型（侦察→武器化→投递→利用→安装→C2→目标达成）及其对应的 MITRE ATT&CK 框架

(2) 掌握基于大语言模型的异常检测、威胁狩猎、攻击溯源等核心技术原理与实现方法

(3) 构建一个覆盖“检测→捕获→溯源”三个环节的端到端攻击行为分析系统

(4) 培养从真实攻击案例中抽象问题、设计系统化解决方案的工程与科研能力

3、系统功能要求（参考性要求，不限制新的思路和新的功能）

系统需实现以下三个核心功能模块，形成完整的攻击行为分析链路：

(1) 内网环境搭建模块

完成近似真实企业网络拓扑设计，搭建企业网络环境，不少于 5 台计算机（不同类型），不少于 DMZ、内网等 2 层网络，不少于高安全防御网络和低安全防御网络等 2 个层次的安全网络环境配置。配置合适的企业网络防御环境，对攻击行为进行检测防御。

(2) 模块一：攻击行为检测模块（Detection）基于大模型实现对潜在攻击行为的自动化识别

a) 多源数据接入：支持至少两种数据源的接入与分析

系统日志（Windows Event Log、Linux Auditd 等）

网络流量日志

终端行为数据（进程创建、文件访问、网络连接等）

b) 异常检测：利用大模型的语义理解能力，从海量日志中识别异常行为模式

可结合检索增强生成（RAG）方法，使 LLM 能够判断异常行为是否为真实攻击

可参考 OMNISEC 的思路，通过 RAG 让 LLM 结合外部知识库进行攻击判定

c) 威胁建模：将检测到的异常行为映射到 MITRE ATT&CK 框架

实现从原始日志到 ATT&CK 技术及攻击者认知特质的端到端自动化推断

d) 告警分级：对检测结果进行风险等级评估（高危/中危/低危）

（3）模块二：攻击行为捕获模块（Capture）对检测到的攻击行为进行深度捕获与证据固化

a) 攻击链重构：基于系统溯源数据（provenance data），重构攻击行为的因果链条

b) 智能体协作捕获：构建多智能体协作框架进行攻击捕获

c) 证据固化：对捕获的攻击行为生成可验证的证据链

d) 可选进阶：在隔离沙箱环境中对攻击载荷进行动态捕获与分析

（4）模块三：攻击溯源模块（Attribution）对捕获的攻击行为进行攻击者归因分析

a) 威胁情报融合：整合公开威胁情报（如 MITRE ATT&CK、CVE、已知 APT 组织 TTP 等）

b) 证据路径推理：基于捕获的证据链进行攻击者归因

c) 攻击者画像：生成攻击者/攻击组织的综合画像

d) 报告生成：自动生成结构化的溯源分析报告

（4）分析场景选择

可从以下三个分析场景中选择至少 2 个进行系统设计与验证：

场景一：APT 攻击全链条检测与溯源

基于公开数据集（如 DARPA TC 数据集）或自行构造的 APT 攻击场景

完成从异常检测→攻击链重构→攻击者归因的完整流程

场景二：AI 智能体滥用行为检测与溯源

聚焦攻击者利用 LLM Agent（如 Claude Code、OpenCode 等）发起的攻击

检测智能体的异常行为模式（如自动化侦察、代码生成攻击载荷等）

溯源攻击者利用 AI 技术栈的完整攻击路径

场景三：勒索软件/数据窃取事件溯源

基于真实的勒索软件或数据泄露事件数据

识别攻击入口、横向移动路径和数据外泄通道

通过 TTP 匹配进行攻击者/攻击组织归因

4、开源参考项目的对比

通过对比其他开源项目，验证在某些方面自研系统的创新性。

5、待测目标要求

三个分析场景中选择至少 2 个场景进行分析。

二．实验报告要求

每组组长提交 1 个总实验报告，组长要发挥实际组织作用，并且和组员一同负责答辩。

实验报告内容要求包括以下内容：目录，小组人员分工及工作量占比，实验环境平台设计、关键实验技术、实验过程和实验测试结果、开发编程项介绍、实验总结。

实验报告提交包含的文档：全面的实验报告（word 版本）、最终汇报 PPT、搭建的服务器或平台环境程序功能演示录像和搭建所用工具的下载地址、安全攻防等相关工具演示录像和所用工具的下载地址、自己编写的程序（含代码）及其功能演示录像等。

实验演示和报告部分综合考核学生掌握基础知识、对课题分析与设计、解决复杂工程问题、方案设计与验证、团队协作与组织、课题答辩与演示等方面的能力。根据实验成果演示的成功与否，实验方案设计和实现的合理性和可行性，实验报告内容的条例性、清晰程度，实验技术的难度和功能完善性，实验方法和技术的先进性，实验的创新性，团队合理组织等方面进行评分。其中，现场演示答辩 50%，实验报告 50%。

三．实验说明

时间：2026 年 7 月 6 日—7 月 17 日

大家周一上午自行完成分组，可跨班组成组，分组名单报给各班学委，各班学委建个群接龙，最后一个班的学委汇总后发给我最终分组名单（包括序号、所选题目、组长姓名学号班级手机号、组员姓名学号班级）。最迟周一晚上把分组

名单发给授课老师 cuibj@bupt.edu.cn，当跨班组建组时，该组在组长所在班里显示所有组员。

组建课程群（课后建立），供大家讨论、开发、完成报告。

实验汇报时间：7月17日周五上午8:50开始，按照04-06班的顺序，按照组长学号的先后顺序介绍。每组准备约20分钟的PPT和相关演示(答辩时限)。

交报告要求：详细的实验报告（电子版）周五下午每组组长在17点前提交各班学委，各班学委18点前提交老师。

实验指导老师崔宝江的联系电话：13611330827

各组同学可通过手机、微信、email随时和实验指导老师沟通交流，课程期间提供一对一的指导和沟通。

大模型费用补助：5人及以下150元、6-10人300元，组长把付款凭证发老师 email: cuibj@bupt.edu.cn，邮件主题：网络空间安全综合实验-大模型费用申请-组号-组长姓名-学号-班号

课程二维码：

